MODULE 21 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Centralised Logging and Security Aggregation

Collect every account's trail, configuration, logs, findings and model invocations in one place, and share resources across accounts safely.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 21 of 52

admin@sthithapragna.com

Evidence must outlive the account that produced it. Send it somewhere the producer cannot reach.

Which stream holds which evidence?

SERVICE	RECORDS	CENTRALISE WITH
CloudTrail	Who called which API, when, from where	Organisation trail to log archive
AWS Config	Resource configuration over time	Organisation aggregator
CloudWatch Logs	Application and service logs	Centralisation rules
GuardDuty	Threat findings from activity	Delegated administrator
Bedrock invocation logs	Prompts, responses, tokens	S3 and CloudWatch Logs per Region

ON THE EXAM

API activity is CloudTrail. What a resource looked like is Config. Prompts and responses are invocation logs.

CloudTrail across the organisation

- **Organisation trail** covers every member account; members cannot stop or change it.
- **Deliver to the log archive account**, with S3 Object Lock and a KMS key.
- **Data events** such as S3 object and Lambda calls are extra, and selected.
- **CloudTrail Lake closed to new customers** on 31 May 2026; AWS points to CloudWatch.
- **Trails, Insights and aggregated events** are unaffected.

> ON THE EXAM
>
> If an answer starts a new CloudTrail Lake event data store, it is stale for a new customer.

Copy the logs, or view them?

LOG CENTRALISATION RULES

Copy into one account

- Rules set in management or delegated admin
- Accounts, OUs or whole organisation
- Copied at ingestion, optional backup Region
- New log data only, not history

CROSS-ACCOUNT OBSERVABILITY

View in place

- Monitoring account links to sources
- Logs, metrics and traces stay put
- Unified dashboards and queries
- Source admins still control retention

THE TIEBREAKER

Retention and tamper resistance need a copy. A single pane of glass only needs viewing.

Amazon Security Lake

- **Normalises to OCSF**, an open schema, stored as Parquet in your S3.
- **AWS sources:** CloudTrail, VPC Flow Logs, Route 53 resolver, EKS audit, WAF, findings.
- **Custom sources** from on premises, other clouds and third parties.
- **Subscribers:** data access to the objects, or query access through Lake Formation.
- **Rollup Regions** consolidate data, which helps with residency.

> ON THE EXAM
>
> Many log formats, one open schema, many consumers including a SIEM: Security Lake.

Security Hub, CSPM and GuardDuty

SERVICE	ANSWERS
GuardDuty	Is something malicious happening?
Inspector	Which workloads have known vulnerabilities?
Security Hub CSPM	Are resources configured to standards?
Security Hub	Which risks matter most, and how could they chain?

ON THE EXAM

Security Hub, generally available since December 2025, correlates the other three into prioritised exposures.

Logging AI model invocations

- **Model invocation logging** captures full requests, responses and token counts.
- **Off by default**, and configured per account and per Region.
- **Destinations:** S3, CloudWatch Logs, or both, in the same account and Region.
- **Large or binary data** over 100 KB, such as images, goes to S3 only.
- **CloudTrail** records the call and caller, not the prompt or response.

> ON THE EXAM
>
> Auditing what a model was asked and answered means invocation logging, enabled in every account and Region.

Sharing resources across accounts

SHARE	WITH	THROUGH
Transit gateway, subnets, prefix lists	Workload accounts	AWS RAM
Route 53 resolver rules	All VPC accounts	AWS RAM
IPAM pools, License Manager configs	OUs or the organisation	AWS RAM
S3 buckets, KMS keys, SQS queues	Other principals	Resource-based policies

ON THE EXAM

Share with an OU or the organisation, so new accounts are included automatically.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Member admins must not stop API logging	Organisation trail
Copy logs from every account, plus backup	CloudWatch centralisation rules
Normalise many log sources for a SIEM	Security Lake
Prioritise chained risks across services	Security Hub
Audit prompts and responses	Model invocation logging
Workload accounts use the network team's TGW	AWS RAM share

ON THE EXAM

Name the evidence first: API calls, configuration, logs, findings or prompts. The service follows.

> Meridian Freight's auditors require a record of every API call in all 140 member accounts, stored for seven years in the log archive account.
>
> Account administrators must not be able to stop or alter the logging, and records must be protected from deletion.

What should the solutions architect implement?

A. A trail in each account, deployed by StackSets, delivering to its own bucket

B. A new CloudTrail Lake organisation event data store with seven-year retention

C. An organisation trail delivering to an S3 bucket in the log archive account with Object Lock in compliance mode

D. An AWS Config organisation aggregator

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **Trail per account**

Account administrators can stop their own trail and delete the bucket.

B **New CloudTrail Lake store**

Closed to new customers since 31 May 2026.

C **Organisation trail with Object Lock**

Members cannot change it; compliance mode prevents deletion.

D **Config aggregator**

Records configuration, not every API call.

THE SIGNAL

Every account, unchangeable by members, undeletable: organisation trail plus Object Lock.

Meridian Freight's security team needs a copy of application logs from 200 accounts in four Regions, held in one security account with a second copy in a backup Region.

Accounts added to the Workloads OU must be included automatically, and source administrators must not be able to delete the central copy.

What should the solutions architect implement?

A. A CloudWatch Logs centralisation rule for the Workloads OU, with a destination account and a backup Region

B. CloudWatch cross-account observability with the security account as monitoring account

C. A subscription filter on each log group, streaming to a Firehose stream in each account

D. Nightly export tasks from each log group to S3

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Centralisation rule

Copies at ingestion, by OU, with a backup Region built in.

B Cross-account observability

Views data in place; source admins still control it.

C Subscription filters

Works, but per log group, per account, with plumbing to maintain.

D Nightly exports

Batch, manual and per log group.

THE SIGNAL

A protected central copy, by OU, with a backup Region: centralisation rules.

> Meridian Freight's security operations centre uses a third-party SIEM and Amazon Athena. It needs CloudTrail, VPC Flow Logs and Route 53 resolver logs from all accounts, plus logs from on-premises firewalls.
>
> All data must be in one open schema in Meridian's own S3, so both tools can query it without custom transformation.

What should the solutions architect recommend?

A Security Hub with all integrations enabled

B An OpenSearch Service domain with custom ingestion pipelines

C CloudWatch Logs centralisation rules

D Amazon Security Lake with the AWS sources and a custom source for the firewalls, and subscribers for the SIEM and Athena

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A **Security Hub**

Aggregates findings, not raw flow, DNS and trail logs.

B **OpenSearch pipelines**

Custom transformation, which the scenario rules out.

C **Centralisation rules**

Copies CloudWatch logs; no open schema or on-premises source.

D **Security Lake**

OCSF in your S3, custom sources, and subscribers for both tools.

THE SIGNAL

Open schema, many sources including non-AWS, many consumers: Security Lake.

> Meridian Freight's security team receives thousands of GuardDuty, Inspector and configuration findings a week across its organisation, and cannot tell which matter most.
>
> It wants findings correlated, so that a vulnerable, internet-exposed instance with an over-privileged role reaching sensitive data is shown as one prioritised risk.

What should the solutions architect recommend?

A. Security Hub CSPM with additional standards enabled

B. AWS Security Hub, enabled across the organisation, using its exposure findings and attack paths

C. GuardDuty Extended Threat Detection only

D. Athena queries over Security Lake, written by the team

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A More CSPM standards

Adds more configuration findings to an already noisy pile.

B Security Hub

Correlates threats, vulnerabilities and misconfigurations into prioritised exposures.

C GuardDuty only

Correlates threat activity, not vulnerabilities and configuration.

D Custom Athena queries

Possible, but building correlation yourself.

THE SIGNAL

Correlate across GuardDuty, Inspector and CSPM into one prioritised risk: the new Security Hub.

> Meridian Freight's compliance team must retain the full prompts and responses of every Amazon Bedrock call made by its applications, including generated images, for review.
>
> Applications run in 12 accounts in two Regions.

What should the solutions architect implement?

A. Model invocation logging to S3 enabled in every account and Region, through infrastructure as code

B. CloudTrail data events for Bedrock in an organisation trail

C. Model invocation logging to CloudWatch Logs only

D. Application code that writes prompts to DynamoDB

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Invocation logging to S3

Full bodies including images, set in each account and Region.

B CloudTrail data events

Record the call and caller, not prompt and response bodies.

C CloudWatch Logs only

Cannot hold images or bodies over 100 KB.

D Application code

Relies on every team doing it, and misses direct calls.

THE SIGNAL

Prompts and responses, including images: invocation logging with an S3 destination.

> Meridian Freight's network team owns a transit gateway and shared VPC subnets in a central network account.
>
> Workload accounts in the Workloads OU, including future ones, must attach to the transit gateway and launch resources into the shared subnets without the network team creating anything per account.

What should the solutions architect configure?

A. A transit gateway in each workload account, peered to the central one

B. VPC peering from each workload VPC to the network VPC

C. IAM roles in the network account that workload teams assume to create resources

D. An AWS RAM resource share of the transit gateway and subnets with the Workloads OU

◆ PAUSE AND DECIDE

What should the solutions architect configure?

A Transit gateway per account

Many gateways and peerings; not sharing at all.

B VPC peering

Per-VPC connections, and no shared subnets.

C Roles into network account

Resources would be owned by the network account, not the workload.

D RAM share with the OU

One share; current and future accounts attach and launch.

THE SIGNAL

Share once with the OU, and new accounts inherit access: AWS RAM.

What to carry out of this module

- **Organisation trail** to a locked log archive; CloudTrail Lake is closed to new customers.
- **Centralisation rules copy**; cross-account observability only views.
- **Security Lake** normalises raw logs; **Security Hub** prioritises findings.
- **Invocation logging** for prompts and responses, per account and Region, S3 for large data.
- **RAM shares** with OUs for transit gateways, subnets and resolver rules.

> ON THE EXAM
>
> Name the evidence, copy it out of reach, then analyse it from security tooling.